

The Human-AI Partnership Framework

Where human judgment belongs

Risk-to-Resilience

PCF 8.3 — Security, compliance, continuity & identity — Value Stream Profile

This value stream comprises one APQC PCF process group: 8.3 Develop and Manage IT Resilience and Risk — spanning 8 Level 3 processes and 53 Level 4 activities, the largest value stream in PCF 8.0 by activity count.

At the activity level, this value stream's work breaks down as 24 Knowledge activities (judgment, synthesis, and interpretation-driven work), 18 Transaction activities (rules-based processing suited to automation), 4 Decision activities, 4 Document activities, and 3 Exception activities — the widest pattern spread of any PCF 8.0 value stream.

At M3 (HITL Design Intent), the value stream's aggregate human-involvement ratio is 55%, down from a 77% undesigned baseline — a 22-point AI convergence opportunity.

L3 PROCESSES	L4 ACTIVITIES	M1 BASELINE H%	M3 DESIGN INTENT H%	Δ M1 → M3
8	53	77%	55%	-22%

KPIs

Business Impact Metric & Formula (where confirmed)	Source
IT resilience/risk cost ratio <i>% of IT operating costs (excl. depreciation/amortization) dedicated to Manage IT Resilience and Risk</i>	APQC OSB
Mean Time to Detect (MTTD) <i>Total time between incident start and detection, summed across incidents ÷ number of incidents in the period</i>	NIST SP 800-61r2
Mean Time to Respond (MTTR) <i>Average time from detection to containment of a security incident</i>	NIST SP 800-61r2
% critical vulnerabilities remediated within SLA <i>Critical/high vulnerabilities remediated within the policy-defined window ÷ total critical/high vulnerabilities identified</i>	NIST SP 800-55

Design Narrative

Risk-to-Resilience follows the same apex pattern as IT Vision-to-Strategy and Data-to-Insight: 8.3.1 (Develop IT compliance, risk, and security strategy) is CISO's own strategy-formation L3, with Director of Cybersecurity holding Accountable for the remaining 7 of 8 L3s — the strongest single-role concentration below the Executive apex of any PCF 8.0 value stream. Cybersecurity Analyst carries Responsible across most of that work, a consistent Managerial-owns/Operational-executes pattern throughout. This is the largest value stream in PCF 8.0 by both L3 count (8) and activity count (53), and carries the widest pattern spread in the domain — all five patterns appear, including 3 of PCF 8.0's total Exception-pattern activities clustered in threat detection/response (8.3.5.7), compliance escalation (8.3.6.4), and breach response (8.3.8.6). Its steepest AI-absorption opportunity sits in 8.3.3.4 (Create and maintain IT security policies, standards, and procedures, Document-pattern, -32 points).

AI Capability Map

Pattern-type distribution across this value stream's activity units. H% figures are the pattern type's standard value at each maturity level, applied consistently across all PCF domains.

Decision <i>Judgment & Authority — gates that stay human by design</i> 4 L4 activities M1 92% → M3 80%	Knowledge <i>Synthesis & Interpretation — judgment-driven work</i> 24 L4 activities M1 85% → M3 65%	Document <i>Content Generation — drafting and communication</i> 4 L4 activities M1 72% → M3 40%	Transaction <i>Rules-Based Processing — suited to automation</i> 18 L4 activities M1 60% → M3 35%	Exception <i>Non-Standard Resolution — human-resolved by nature</i> 3 L4 activities M1 95% → M3 82%
---	--	--	--	--

Process Accountability

Process Accountability	Tier	L3 Processes	L4 Activities
CISO	Executive	8.3.1	10

The Human-AI Partnership Framework

PCF 8.3 — Risk-to-Resilience — Value Stream Profile

Process Accountability	Tier	L3 Processes	L4 Activities
Director of Cybersecurity	Managerial	8.3.2, 8.3.3, 8.3.4, 8.3.5, 8.3.6, 8.3.7, 8.3.8	43

Handoff Points

The stream opens with CISO-accountable strategy formation (8.3.1), then hands to Director of Cybersecurity for the remaining seven L3s — resilience strategy (8.3.2), risk/compliance/security control (8.3.3), continuity planning (8.3.4), security/privacy/data protection (8.3.5), compliance assessment (8.3.6), resilience and continuity operations (8.3.7), and identity/authorization management (8.3.8).

Cybersecurity Analyst carries Responsible across most of Director of Cybersecurity's lane, with the stream's three Exception-pattern activities — threat detection and response (8.3.5.7), compliance escalation (8.3.6.4), and breach response (8.3.8.6) — marking where routine monitoring hands off to non-standard, judgment-driven resolution.

Governed Decision Points

Every Decision/Exception-pattern activity in the value stream, including those embedded inside Mixed-labeled steps.

PCF	Decision	Authority	Impact	Escalates To	Trigger
8.3.1.3	Establish IT risk tolerance	CISO	Strategic — sets the domain's acceptable risk posture	CEO / Board (outside the IT role catalog)	Risk tolerance decision has enterprise-wide financial or regulatory exposure implications
8.3.1.4	Establish risk ownership	CISO	Governance — assigns accountability for IT risk categories	CEO / Board (outside the IT role catalog)	Ownership assignment spans multiple business units or existing role catalog gaps
8.3.1.6	Establish compliance objectives	CISO	Strategic + Regulatory	CEO / Board (outside the IT role catalog)	Objectives involve new regulatory scope or conflict with existing enterprise compliance commitments
8.3.2.3	Prioritize IT risks	Director of Cybersecurity	Strategic + Operational	CISO (Executive)	Risk prioritization affects enterprise-level resource allocation or conflicts with CISO-set risk tolerance
8.3.5.7	Monitor/analyze network intrusion detection data and resolve threats	Director of Cybersecurity	Operational + Security — direct breach risk	CISO (Executive)	Detected threat indicates active compromise or exceeds standard incident-response procedures
8.3.6.4	Identify and escalate IT compliance issues and remediation requirements	Director of Cybersecurity	Regulatory + Reputational	CISO (Executive)	Compliance issue involves potential regulatory violation or requires enterprise-level remediation budget
8.3.8.6	Respond to IT information security and network breaches	Director of Cybersecurity	Security + Reputational + Regulatory — the domain's highest-severity incident type	CISO / CEO / Board (Executive)	Confirmed breach with data exposure, regulatory notification requirements, or material business impact